Project Report: Enterprise Ransomware Risk Assessment

Student Name: Yadhu

Course: IBM SkillsBuild / BharatCares Cybersecurity Bootcamp (2026)

Project Topic: Enterprise Ransomware Assessment (Mapped to NIST CSF Framework)

1. Executive Summary

This project evaluates the organization's enterprise risk profile against potential ransomware attacks. Using the NIST Cybersecurity Framework (CSF) core functions—Identify, Protect, Detect, Respond, and Recover—this assessment establishes a structured Risk Register, identifies key operational vulnerabilities, and provides prioritized remediation controls.

2. Methodology & Framework

The risk assessment methodology follows the standard risk calculation model: Risk = Likelihood x Impact.

- Likelihood Scale: Low (1), Medium (2), High (3)

- Impact Scale: Low (1), Medium (2), High (3)

- Risk Rating: Low (1-2), Medium (3-4), High (6-9)

3. Corporate Ransomware Risk Register

- RR-01 | PR.AC (Access Control) | Initial compromise via phishing email leading to credential theft. | Likelihood: High (3) | Impact: High (3) | Overall Risk: High (9) | Mitigation: Enforce Multi-Factor Authentication (MFA) and phishing training.

- RR-02 | PR.DS (Data Security) | Unencrypted backups targeted or deleted during ransomware execution. | Likelihood: High (3) | Impact: High (3) | Overall Risk: High (9) | Mitigation: Enforce immutable, air-gapped 3-2-1 backup policies.

- RR-03 | DE.CM (Continuous Monitoring) | Lateral movement undetected due to lack of endpoint detection logs. | Likelihood: Medium (2) | Impact: High (3) | Overall Risk: High (6) | Mitigation: Deploy EDR agents with centralized SIEM monitoring.

- RR-04 | RS.RP (Response Planning) | Delayed incident isolation resulting in network-wide ransomware spread. | Likelihood: Medium (2) | Impact: Medium (2) | Overall Risk: Medium (4) | Mitigation: Develop automated endpoint isolation playbooks.

- RR-05 | RC.RP (Recovery Planning) | Extended downtime due to untested disaster recovery procedures. | Likelihood: Medium (2) | Impact: High (3) | Overall Risk: High (6) | Mitigation: Conduct quarterly table-top exercises and backup tests.

4. Key Recommendations

1. Immediate (0-30 Days): Mandate Multi-Factor Authentication (MFA) across all remote access and cloud apps.

2. Short-Term (30-60 Days): Isolate critical backups using write-once-read-many (WORM) storage.

3. Medium-Term (60-90 Days): Implement network segmentation between user stations and core servers.